Lab 33 — Active Reconnaissance with Nmap

After passive OSINT (Lab 32), the next pentest phase is **active recon**. You will fingerprint a local target with Nmap, run NSE scripts, and read the timing knobs that decide stealth vs. speed.

Run on https://killercoda.com/playgrounds/scenario/ubuntu

Required software (free, apt): - `nmap` - `nginx`, `openssh-server` (targets)

Step 1 — Install

```
apt update && apt install -y nmap nginx openssh-server
```

```
systemctl start nginx
```

```
systemctl start ssh
```

We start both `nginx` (port 80) and `ssh` (port 22) so the later version- and NSE-detection steps have real services to fingerprint on this host.

Step 2 — Host discovery (no port scan yet)

```
nmap -sn 127.0.0.0/30
```

`-sn` is "ping scan" — confirms a host is alive without scanning ports.

Step 3 — TCP SYN scan (the default)

```
nmap -sS -p 1-1024 127.0.0.1
```

`-sS` sends SYN, reads the SYN-ACK, never completes the handshake — half-open scan.

Step 4 — Service / version detection

```
nmap -sV -p 22,80 127.0.0.1
```

Replies: `OpenSSH 8.x` and `nginx 1.x`. Now you can map versions to known CVEs.

Step 5 — OS fingerprint

```
nmap -O 127.0.0.1
```

`-O` infers the OS from TCP/IP stack quirks.

Step 6 — NSE (Nmap Scripting Engine)

```
nmap --script=banner,http-headers,ssh2-enum-algos -p 22,80 127.0.0.1
```

`http-headers` reveals server banner; `ssh2-enum-algos` lists enabled crypto — feeds straight into TLS hardening (Lab 19).

Step 7 — Vulnerability scripts

```
nmap --script=vuln -p 80 127.0.0.1
```

Scripts in the `vuln` category check for CVEs they have signatures for (Heartbleed, Shellshock, slowloris, etc.).

Step 8 — Timing & stealth (`-T0` … `-T5`)

	Use case
`-T0`	Paranoid (IDS evasion, glacial)
`-T2`	Polite (low bandwidth)
`-T3`	Default
`-T4`	Aggressive (lab / authorised pentest)

	Use case
-T5	Insane (loud, unreliable)

```
time nmap -T4 -p- 127.0.0.1 | tail -10
```

Step 9 — Save in three formats for reporting

```
nmap -sV -oA scan-127 127.0.0.1
ls scan-127.*
```

`.nmap` (human), `.gnmap` (grep), `.xml` (machine). Most reporting tools consume the XML.

Step 10 — Rules of engagement reminder

Run these scans **only** on: - Hosts you own. - Targets explicitly listed in a signed Statement of Work / Rules of Engagement. - CTFs and intentionally vulnerable practice ranges (HackTheBox, TryHackMe).

Unauthorised scanning of third-party systems is illegal in most jurisdictions,

including the Singapore Computer Misuse Act.

Free online tools

- **Nmap docs + NSE library** — https://nmap.org/book
- **Zenmap GUI** — https://nmap.org/zenmap
- **Masscan** — https://github.com/robertdavidgraham/masscan
- **RustScan** — https://github.com/RustScan/RustScan
- **HackTheBox / TryHackMe** — legal practice targets
- **Vulnhub VMs** — https://www.vulnhub.com

What you learned

- The four nmap scan modes you must know (`-sn`, `-sS`, `-sV`, `-O`).
- That NSE is the bridge between port scanning and vulnerability scanning.
- The legal boundary: authorisation, in writing, before any active scan.